

Security Requirements Use-Case



1 Hintergrund

Sie werden gebeten für ein neuartiges mobile Payment System eine Sicherheitsanalyse zu erstellen. Das System wird nachfolgend beschrieben.

1.1 Situation

Ein Verkäufer / Shop (Merchant) bietet dem Kunden (Customer) die Möglichkeit an mit einer Mobile App auf seinem Smartphone zu bezahlen. Es gibt zwei Möglichkeit, Scan eines QR-Codes oder mittels NFC Kommunikation mit dem Kassensystem (Point of Sale).

1.2 Geld Laden

Die Mobile Payment App kann folgendermassen mit Geld geladen werden

- Pre-Pay: Direktes Laden mit einem Voucher
- Kredit: Anhängen von Kreditkarten
- Debit: Verbinden von Konto (Bank)

1.3 Zahlarten / Geldfluss

- Direkt an einem Kassensystem
 - Mittels QR-Code, (Backup: 8 Stelliger Code durch manuelle Eingabe)
 - Via NFC Kommunikation mit dem Kassensystem
- Webshop
 - Mittels QR-Code, (Backup: 8 Stelliger Code durch manuelle Eingabe)
- Peer to Peer Überweisung an einen anderen Nutzer (via Telefonnummer)

1.4 Zusatzservices

Der Mobile Paymentanbieter unterstützt folgende zusätzliche Mehrwert Services

- Loyalty / Digital Marketing:
 - Couponing (Rabatte, Coupons)
 - Zeit, Kontext oder Location abhängig gesteuert
 - Stempelkarten (z. Bsp. Jeder 10te Kaffee gratis)
- Gift Vouchers (Prepay Geschenkkarten)

1.5 System Bestandteile

Bedenken Sie minimal folgende Systembestandteil

- Mobile Applikation (Offiziell zugelassen vom entsprechenden Appstore → iOS, Android)
- Payment Backend System vom Mobile Payment Anbieter mit folgender Teilung
 - Backend: Verwaltung der Merchants (internes System)
 - Backend: Verwaltung der Kunden (internes System)
 - Frontend: Administration Oberfläche für Selbstadministration der Merchants (https, extern zugänglich, Login via 2FA)
 - Backend: Core Banking System mit den finanziellen Transaktionen und der Buchführung der Konten nach FINMA Regeln (Webservices, externe Schnittstellen Banken, Kassensysteme etc.)
- Kassensystem (PoS) vom Merchant

1.6 Annahmen

Nachfolgenden Annahmen werden getroffen um die Komplexität zu begrenzen:

- Die Kassen und Kassensystem sind NFC fähig ohne ein zusätzliches Gerät
- Es gibt nur einen einzigen Kassensystemanbieter
- Es gibt nur einen einzigen Kreditkartenanbieter
- Es gibt nur einen Anbieter als Bank
- Es gibt nur je ein Model für Android und iOS

Eigene, von Ihnen getroffene Annahmen dokumentieren Sie bitte klar und verständlich.